



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## CISA Orders Federal Agencies to Patch Actively Exploited Joomla JCE RCE by 2026-06-19

CVE / Vulnerability Threat Intelligence Report

|                       |                                                |
|-----------------------|------------------------------------------------|
| <b>Classification</b> | TLP:CLEAR                                      |
| <b>Published</b>      | 2026-06-17                                     |
| <b>Version</b>        | 1.0                                            |
| <b>Author</b>         | Lost Boys Cyber                                |
| <b>Report Type</b>    | CVE / Vulnerability Threat Intelligence Report |

TLP:CLEAR | Lost Boys Cyber | CISA Orders Federal Agencies to Patch Actively Exploited Joomla JCE RCE by 2026-06-19 - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

# CISA Orders Federal Agencies to Patch Actively Exploited Joomla JCE RCE by 2026-06-19

## 1. Executive Summary

CISA added CVE-2026-48907, an actively exploited improper access control vulnerability in the Widget Factory Joomla Content Editor (JCE) extension, to the Known Exploited Vulnerabilities (KEV) Catalog on 2026-06-16 and directed Federal Civilian Executive Branch agencies to remediate affected publicly exposed assets by 2026-06-19 under BOD 26-04. The vulnerability affects JCE versions 1.0.0 through 2.9.99.4 and enables unauthenticated attackers to create or import editor profiles that permit PHP upload and execution.

Lost Boys Cyber assesses CVE-2026-48907 as a critical, internet-scale web application risk for any organization operating Joomla sites with JCE, especially public websites, extranets, contractor portals, small business manufacturing sites, and legacy web estates maintained by third parties. The exploit path is low complexity, requires no privileges or user interaction, is automatable, and results in server-side PHP code execution. CISA, the vendor, and independent vulnerability research reporting all indicate active exploitation or public exploit availability.

Defender priority is two-fold: patch and hunt. Upgrading to JCE 2.9.99.6 or later closes the vulnerable path, but the vendor explicitly warns that updating does not remove rogue profiles, uploaded webshells, stolen credentials, or other implants already placed on compromised servers. Organizations should therefore combine rapid update or stopgap patching with log review for unauthenticated profile import activity, inspection of JCE editor profiles, search for PHP artifacts in uploadable folders, and credential rotation for administrator, database, hosting, FTP/SFTP, and reused credentials.

| Field               | Assessment                                                                                                                                                                        |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Report ID           | LBC-VTI-2026-084                                                                                                                                                                  |
| CVE                 | CVE-2026-48907                                                                                                                                                                    |
| Vendor / Product    | Widget Factory / Joomla Content Editor (JCE) extension for Joomla                                                                                                                 |
| Vulnerability Class | CWE-284 Improper Access Control; unauthenticated profile import leading to PHP upload and execution                                                                               |
| Severity            | Critical; CVSS v4.0 base score 10.0                                                                                                                                               |
| Exploitation Status | Active exploitation reported; public exploit code/research available; CISA KEV listed                                                                                             |
| CISA KEV Due Date   | 2026-06-19                                                                                                                                                                        |
| Fixed Version       | JCE 2.9.99.5 patched the flaw; JCE Pro 2.9.99.6 or later is recommended due to additional hardening                                                                               |
| Analyst Confidence  | High for CVE facts, KEV status, fixed-version guidance, and exploitation urgency; medium for environment-specific exposure until inventory confirms Joomla/JCE deployment details |

## 2. Intelligence Requirement

This report addresses the following intelligence requirement: What does CISA's urgent KEV action for CVE-2026-48907 mean for defenders responsible for public web infrastructure, client portals, manufacturing-support websites, and OT-adjacent business systems, and what actions should be prioritized before and after the 2026-06-19 remediation deadline?

| Requirement | Analytic Answer |
|-------------|-----------------|
|-------------|-----------------|

|                                                 |                                                                                                                                                                                                                                                                                            |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                 |                                                                                                                                                                                                                                                                                            |
| What changed?                                   | CISA listed CVE-2026-48907 in KEV on 2026-06-16 after evidence of active exploitation and required rapid remediation by 2026-06-19 for in-scope federal assets.                                                                                                                            |
| Who is exposed?                                 | Joomla deployments using JCE 1.0.0 through 2.9.99.4, with highest urgency for internet-facing sites, portals, shared-hosting deployments, and any site where the JCE component is reachable by unauthenticated visitors.                                                                   |
| What is the attacker outcome?                   | Remote PHP execution through a rogue editor profile and upload path, enabling webshell placement, credential theft, persistence, defacement, redirect injection, staging, or broader server compromise.                                                                                    |
| Why does patching alone not close the incident? | Updating JCE prevents re-entry but does not delete already-created rogue editor profiles, uploaded PHP files, stolen credentials, or secondary malware planted before remediation.                                                                                                         |
| What should defenders do first?                 | Inventory Joomla/JCE, update to JCE 2.9.99.6 or later where possible, use the vendor stopgap patch only where legacy constraints block upgrade, search for <code>`task=profiles.import`</code> activity and rogue profiles, scan upload folders for PHP artifacts, and rotate credentials. |
| What is not known?                              | Public sources do not attribute exploitation to a named actor, do not provide a definitive victim count, and do not identify a single universal IOC beyond behavior, request path, rogue profiles, and suspicious uploaded PHP files.                                                      |

Analyst assumptions: this assessment treats the CISA KEV entry, the CVE record, JCE vendor advisory, and independent technical write-ups as authoritative for vulnerability mechanics and urgency. Detection content below is behavior-based and must be tuned to local web-server, WAF, EDR, hosting, and Joomla audit telemetry.

### 3. Source Review and Confidence

| Source                                             | Contribution                                                                                                                                                                           | Reliability | Confidence |
|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|------------|
| CISA KEV Catalog, CVE-2026-48907 entry, 2026-06-16 | Confirms KEV status, due date, vendor/product, required action, CWE-284 classification, and active exploitation basis.                                                                 | High        | High       |
| CVE Program / Joomla CNA record                    | Defines affected product, affected versions 1.0.0-2.9.99.4, CVSS v4.0 score 10.0, exploit maturity <code>`ATTACKED`</code> , and title indicating RCE in JCE before 2.9.99.5.          | High        | High       |
| JCE vendor advisory, 2026-06-12                    | Provides remediation guidance, active exploitation warning, cleanup steps, affected legacy constraints, and field indicators such as rogue profiles and suspicious PHP files in upload | High        | High       |

|                                          |                                                                                                                                                                     |             |                                                                      |
|------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|----------------------------------------------------------------------|
|                                          | folders.                                                                                                                                                            |             |                                                                      |
| BleepingComputer, 2026-06-17             | Summarizes CISA directive, federal remediation deadline, exploitability, vendor fix, and CISA BOD 26-04 context.                                                    | Medium-High | High where corroborated by primary sources                           |
| YesWeHack technical analysis, 2026-06-12 | Provides technical root-cause explanation: unauthenticated `profiles.import`, insufficient authorization, insufficient file-extension validation, and exploit flow. | Medium-High | Medium-High; validate PoC-specific detail before operational testing |

Key facts assessed with high confidence:

- CVE-2026-48907 affects Joomla Content Editor (JCE) versions 1.0.0 through 2.9.99.4.
- The flaw permits unauthenticated creation/import of editor profiles that can permit PHP upload and execution.
- CISA listed the vulnerability in KEV on 2026-06-16 and set a 2026-06-19 remediation due date for in-scope federal systems.
- The CVE record assigns CVSS v4.0 10.0 Critical with network attack vector, low complexity, no privileges, no user interaction, automatable exploitation, and exploit maturity `ATTACKED`.
- JCE 2.9.99.5 patched the vulnerability; JCE Pro 2.9.99.6 or later is recommended because it adds hardening.
- Updating is not sufficient for already-compromised sites; responders must preserve evidence, remove rogue profiles and uploaded payloads, rotate credentials, and scan the server.

Confidence caveats:

- Public reporting does not identify a named intrusion set or ransomware family tied to exploitation.
- Hosting-provider telemetry varies widely; many shared-hosting customers may not retain sufficient logs to prove initial access timing.
- Detection must be tuned because Joomla routes requests through `index.php`, and legitimate administrative behavior can resemble profile or media-management activity if not scoped to authentication state, source, and change control.

## 4. Key Findings

| ID | Finding                                                                                                                            | Defensive Implication                                                                                                                | Priority |
|----|------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|----------|
| F1 | CVE-2026-48907 is an unauthenticated, network-reachable RCE path in a widely used Joomla editor extension.                         | Public Joomla/JCE sites can be compromised without valid credentials or user interaction.                                            | Critical |
| F2 | The exploit chain abuses JCE profile import and upload policy behavior to enable PHP execution.                                    | Hunt for unauthenticated `task=profiles.import` activity, rogue JCE profiles, and unexpected PHP files under uploadable directories. | Critical |
| F3 | CISA KEV requires remediation by 2026-06-19 for FCEB assets and recommends BOD 26-04 risk-based prioritization for exposed assets. | Organizations should treat public exposure and total-control impact as emergency patch drivers, not routine CMS maintenance.         | Critical |
| F4 | Vendor guidance states attacks are automated and public                                                                            | Assume opportunistic mass exploitation; do not rely on                                                                               | Critical |

|    |                                                                                   |                                                                                                                                        |      |
|----|-----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|------|
|    | exploit code exists.                                                              | obscurity, no public registration, or low site traffic.                                                                                |      |
| F5 | Patching does not clean an already-compromised site.                              | Incident response must include evidence preservation, profile review, file-system scan, credential rotation, and hosting-level review. | High |
| F6 | Legacy sites may be unable to run 2.9.99.6 due to PHP/Joomla version constraints. | Stopgap patching may reduce immediate risk, but unsupported PHP/Joomla remains a residual risk requiring migration planning.           | High |

## Vulnerability detail matrix:

| Field                       | Value                                                                                               |
|-----------------------------|-----------------------------------------------------------------------------------------------------|
| CVE                         | CVE-2026-48907                                                                                      |
| Vulnerability Name          | Widget Factory Joomla Content Editor Improper Access Control Vulnerability                          |
| Affected Product            | Joomla Content Editor (JCE) extension for Joomla                                                    |
| Affected Versions           | 1.0.0 through 2.9.99.4 per CVE CNA record                                                           |
| Fixed / Recommended Version | 2.9.99.5 fixes the issue; 2.9.99.6 or later recommended by vendor due to added hardening            |
| Weakness                    | CWE-284 Improper Access Control                                                                     |
| CAPEC                       | CAPEC-242 Code Injection                                                                            |
| CVSS v4.0                   | 10.0 Critical;<br>`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H/E:A/AU:Y/U:Red`  |
| Exploitability              | Network, low complexity, no privileges, no user interaction, automatable; exploit maturity attacked |
| Primary Impact              | PHP code upload and execution, webshell placement, site/server compromise                           |
| KEV Status                  | Added 2026-06-16; due 2026-06-19; known ransomware campaign use unknown                             |

## Exposure matrix:

| Exposure Pattern                      | Why It Matters                                                                          | Immediate Control                                                                                                 |
|---------------------------------------|-----------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Internet-facing Joomla site using JCE | Highest-risk path for automated exploitation and public scanning.                       | Update to 2.9.99.6+, restrict access where possible, review logs and profiles.                                    |
| Public site on shared hosting         | Limited host-level visibility and fast log rotation may impair incident reconstruction. | Export web logs immediately, request provider support, scan all web roots, rotate hosting/FTP/database passwords. |

|                                                 |                                                                                                                                             |                                                                                                         |
|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Contractor, supplier, or client portal          | Compromise may expose credentials, documents, or business process data and create pivot paths.                                              | Patch, enforce MFA for administrative access, verify server-side implants, review portal user accounts. |
| Manufacturing support website separate from OT  | Direct OT compromise is not implied, but attackers may use web footholds for brand abuse, credential theft, or supplier/customer targeting. | Treat as public-web compromise risk; do not assume OT segmentation eliminates business impact.          |
| Legacy PHP/Joomla environment unable to upgrade | Stopgap patch may close this flaw, but the platform remains exposed to unsupported-stack vulnerabilities.                                   | Apply vendor patch package only as a temporary measure; plan migration to supported PHP/Joomla/JCE.     |

## 5. Threat Context

CVE-2026-48907 is a high-urgency CMS extension vulnerability because it combines four characteristics defenders should treat as escalation triggers: it is pre-authentication, it is internet-reachable, it is automatable, and it directly enables code execution. The practical attacker workflow is not credential guessing; it is abuse of a reachable JCE profile import path and weak access control to create an editor profile or upload path that permits executable PHP content. Once PHP execution is available, attackers can deploy webshells, credential stealers, redirectors, spam tooling, SEO poisoning payloads, cryptocurrency miners, staging scripts, or additional backdoors.

The vendor advisory notes that attackers may create unfamiliar editor profiles, tune profile upload extensions to include PHP or other script types, and place suspicious PHP files in locations such as ``images``, ``media``, or ``tmp``. It also warns that a site without public registration is still exposed because the vulnerability does not depend on normal account creation. This matters for organizations that historically deprioritized CMS hardening because only administrators could authenticate to the site.

For manufacturing and small industrial organizations, the immediate risk is most likely business-web compromise rather than direct process manipulation. However, public web footholds can still support credential theft, email or VPN password reuse, supplier impersonation, ransomware staging, and brand-abuse operations. Joomla sites are also common in long-lived, low-maintenance environments where patch lag, shared hosting, legacy PHP constraints, and third-party web-maintenance arrangements complicate emergency response.

| Scenario                                             | Preconditions                                                          | Likely Objective                                                                     | Defensive Focus                                                                                         |
|------------------------------------------------------|------------------------------------------------------------------------|--------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Opportunistic mass exploitation of public Joomla/JCE | Internet-facing site runs JCE <= 2.9.99.4                              | Drop webshell, redirector, spam/SEO payload, credential stealer, or persistence file | Patch, block/review import endpoint behavior, scan upload folders, preserve logs                        |
| Targeted compromise of client or supplier portal     | Portal uses vulnerable JCE and hosts sensitive client/vendor workflows | Access portal data, steal credentials, stage follow-on phishing                      | Administrative audit, credential rotation, document-access review, account anomaly detection            |
| Shared-hosting compromise with limited logs          | Vulnerable site on commodity hosting, short retention                  | Persistent webshell and cross-site contamination across same hosting account         | Provider escalation, full account scan, isolate web roots, rotate FTP/SFTP/database/hosting credentials |
| Post-patch residual compromise                       | JCE updated after exploitation occurred                                | Maintain access through existing PHP payload or stolen credentials                   | Rogue profile deletion, file-system review, malware scan, server rebuild if integrity cannot be proven  |
| Legacy site unable to upgrade                        | PHP/Joomla too old for JCE 2.9.99.6                                    | Continued exposure through unsupported stack even after                              | Temporary vendor patch, network restrictions,                                                           |

|  |  |               |                                         |
|--|--|---------------|-----------------------------------------|
|  |  | stopgap patch | accelerated migration/decommission plan |
|--|--|---------------|-----------------------------------------|

MITRE ATT&CK mapping should be read as technique relevance for defender planning, not attribution to a specific campaign:

| Matrix     | Technique | Name                                                          | Rationale                                                                                                                                        |
|------------|-----------|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Enterprise | T1190     | Exploit Public-Facing Application                             | The vulnerable JCE component is reachable through public Joomla web routes and can be exploited without authentication.                          |
| Enterprise | T1505.003 | Server Software Component: Web Shell                          | PHP upload and execution enables webshell deployment on compromised Joomla servers.                                                              |
| Enterprise | T1105     | Ingress Tool Transfer                                         | Attackers with PHP execution may download secondary tools, implants, or scripts to the server.                                                   |
| Enterprise | T1059.006 | Command and Scripting Interpreter: Python / Unix Shell caveat | Webshells often invoke local interpreters or shell commands, but the specific post-exploitation command set is not disclosed by public sources.  |
| Enterprise | T1078     | Valid Accounts                                                | Credential theft or reuse after compromise may enable continued access; this is a response consideration rather than a confirmed initial vector. |
| Enterprise | T1565.002 | Data Manipulation: Transmitted Data Manipulation              | CMS compromise can support web redirects, injected scripts, or defacement; validate against observed payloads before asserting.                  |

## 6. Detection and Hunting

Detection should start with confirmed asset scope: identify every Joomla site, JCE extension version, web root, hosting account, administrative owner, and log source. Treat any internet-facing JCE version 2.9.99.4 or earlier as exposed until proven patched and reviewed. Because public sources do not provide a single definitive malicious hash or source IP list, detection should combine web request telemetry, Joomla/JCE state, file-system inspection, server-side process telemetry, and credential/account activity.

| Analytic                                            | Telemetry Source                                      | Goal                                                              | Notes                                                                                                         |
|-----------------------------------------------------|-------------------------------------------------------|-------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Unauthenticated requests to JCE profile import path | Apache/Nginx/IIS access logs, WAF, CDN, reverse proxy | Identify exploit attempts and earliest potential compromise time. | Search for `option=com_jce` with `task=profiles.import`; include POST requests and unusual multipart uploads. |
| Rogue or newly created JCE                          | Joomla administrator view,                            | Detect attacker-created profile                                   | Vendor notes rogue profiles                                                                                   |



|                                     |                                                                                 |                                                                       |                                                                                                                            |
|-------------------------------------|---------------------------------------------------------------------------------|-----------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| editor profiles                     | database backup, application audit logs                                         | enabling executable uploads.                                          | may have meaningless names and may be ordered to the top.                                                                  |
| PHP files in uploadable directories | EDR, file integrity monitoring, hosting malware scan, shell find commands       | Identify likely webshell or payload placement.                        | Review `images`, `media`, `tmp`, and any JCE-configured upload directory for PHP or `php` in filenames.                    |
| Changed upload extension policy     | JCE profile configuration and database                                          | Detect profiles permitting PHP or other executable script extensions. | Review Image Manager, File Browser, Template Manager, or custom plugin upload policies.                                    |
| Post-exploitation webshell behavior | Web logs, process telemetry, EDR, command-line logging                          | Identify commands executed through PHP payloads.                      | Look for short PHP file requests with command parameters, outbound curl/wget, archive extraction, or chmod/chown activity. |
| Credential use after patching       | Joomla admin logs, hosting control panel, SSH/SFTP/FTP logs, database auth logs | Detect continued access through stolen credentials.                   | Rotate credentials and invalidate sessions rather than relying on password-change evidence alone.                          |

### 6.1 Web Log Hunt: JCE Profile Import Activity

```
index=web sourcetype IN (access_combined, nginx:access, apache:access) earliest=-30d
("option=com_jce" AND "task=profiles.import")
| eval is_post=if(match(_raw,"\"POST \""),1,0)
| stats earliest(_time) as first_seen latest(_time) as last_seen count values(method) as methods
values(status) as statuses values(uri_path) as paths values(useragent) as user_agents by src_ip host
| convert ctime(first_seen) ctime(last_seen)
| sort first_seen
```

### 6.2 Microsoft Defender XDR Hunt: Web Server Activity After Suspicious JCE Requests

```
// Replace JoomlaServers with local server hostnames or device IDs.
let Lookback = 30d;
let JoomlaServers = dynamic(["WEB-JOOMLA-01", "WEB-JOOMLA-02"]);
let SuspiciousWebRequests =
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where DeviceName in~ (JoomlaServers)
| where RemoteUrl has_all ("option=com_jce", "task=profiles.import")
| project RequestTime=Timestamp, DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName;
let WebServerProcessActivity =
DeviceProcessEvents
| where Timestamp > ago(Lookback)
| where DeviceName in~ (JoomlaServers)
| where InitiatingProcessFileName in~ ("php-fpm", "php", "apache2", "httpd", "nginx", "w3wp.exe")
| where ProcessCommandLine has_any ("curl", "wget", "chmod", "base64", "bash -c", "powershell",
"certutil", "python", "perl", "nc ", "ncat")
| project ProcessTime=Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine,
AccountName;
SuspiciousWebRequests
| join kind=innerunique (WebServerProcessActivity) on DeviceName
| where ProcessTime between (RequestTime .. RequestTime + 2h)
| project RequestTime, ProcessTime, DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName,
FileName, ProcessCommandLine, AccountName
| order by RequestTime desc
```

### 6.3 Sigma Rule: Suspicious JCE Profile Import Request

```
title: Joomla JCE Profile Import Exploitation Attempt
id: 3b7efaf5-cdae-44d9-9f74-489070001084
```

```

status: experimental
description: Detects web requests to the Joomla Content Editor profile import task associated with
CVE-2026-48907 exploitation attempts.
references:
  - https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-48907
  - https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites
  - https://cveawg.mitre.org/api/cve/CVE-2026-48907
author: Lost Boys Cyber
date: 2026/06/17
tags:
  - attack.initial_access
  - attack.t1190
  - cve.2026-48907
logsource:
  category: webserver
detection:
  selection_jce:
    cs-uri-query|contains|all:
      - 'option=com_jce'
      - 'task=profiles.import'
  selection_raw:
    url|contains|all:
      - 'option=com_jce'
      - 'task=profiles.import'
  condition: selection_jce or selection_raw
fields:
  - src_ip
  - http_method
  - url
  - user_agent
  - status
falsepositives:
  - Legitimate administrator profile import activity; validate authentication state, source IP, change
ticket, and timing.
level: high

```

## 6.4 File-System Hunt: Suspicious PHP in Joomla Upload Paths

```

# Run from the Joomla site root or hosting account root after preserving evidence.
# Review results before deleting; collect hashes and timestamps for incident scoping.
find ./images ./media ./tmp -type f \( -iname '*.php' -o -iname '*.php*' -o -iname '*.phtml' -o -iname
 '*.phar' \) \
-printef '%TY-%m-%d %TH:%TM:%TS %s %p\n' 2>/dev/null | sort

```

## 6.5 YARA Triage Rule: Generic PHP Webshell Traits in Upload Folders

```

rule LBC_Generic_PHP_Webshell_Triage_Upload_Folder
{
  meta:
    description = "Generic triage rule for suspicious PHP webshell constructs in Joomla upload folders;
not specific to CVE-2026-48907"
    author = "Lost Boys Cyber"
    date = "2026-06-17"
    cve = "CVE-2026-48907"
  strings:
    $php = "<?php" ascii nocase
    $eval = "eval(" ascii nocase
    $assert = "assert(" ascii nocase
    $system = "system(" ascii nocase
    $shell_exec = "shell_exec(" ascii nocase
    $passthru = "passthru(" ascii nocase
    $base64 = "base64_decode(" ascii nocase
    $gzinflate = "gzinflate(" ascii nocase
    $cmd_param1 = "$_REQUEST[" ascii nocase
    $cmd_param2 = "$_POST[" ascii nocase
    $cmd_param3 = "$_GET[" ascii nocase
  condition:

```

```
$php and 2 of ($eval,$assert,$system,$shell_exec,$passthru,$base64,$gzinflate,$cmd_param*)
}
```

Hunt triage questions:

- Was the destination site running JCE 2.9.99.4 or earlier at the time of suspicious access?
- Did unauthenticated traffic reach `index.php?option=com\_jce&task=profiles.import`, especially via POST or multipart upload?
- Do JCE editor profiles contain unfamiliar names, unusual ordering, or permitted extensions including PHP, PHTML, PHAR, or script-like variants?
- Are there PHP files in `images`, `media`, `tmp`, or custom JCE upload paths that do not map to expected application code?
- Did suspicious web requests precede outbound connections, shell commands, new cron jobs, modified `.htaccess`, new Joomla administrators, or password resets?
- Were database, hosting, FTP/SFTP, Joomla administrator, or reused credentials changed after suspected compromise?

## 7. Recommendations

| Priority | Owner                         | Recommendation                                                                                                                                           | Target State                                                                                                 |
|----------|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Critical | Web / Platform Engineering    | Inventory Joomla sites and identify JCE extension versions, exposure, hosting provider, web root, and business owner.                                    | Complete list of vulnerable, patched, decommissioned, and exception-approved assets.                         |
| Critical | Web / Platform Engineering    | Upgrade affected sites to JCE 2.9.99.6 or later. If legacy constraints prevent upgrade, apply the vendor stopgap patch only as temporary risk reduction. | No internet-facing JCE <= 2.9.99.4 remains reachable without documented exception and compensating controls. |
| Critical | Incident Response             | Preserve web logs, JCE profile exports, suspicious files, and hashes before deletion.                                                                    | Evidence supports earliest-compromise determination, scoping, and potential rebuild decisions.               |
| Critical | Incident Response / Web Admin | Review and delete rogue JCE profiles only after preserving copies; inspect permitted extension lists and upload paths.                                   | JCE profile state matches authorized configuration, and attacker-added upload permissions are removed.       |
| High     | SOC / Detection Engineering   | Deploy hunts for `task=profiles.import`, suspicious PHP in upload folders, and webserver-launched shell utilities.                                       | Alerts correlate web request, file creation, process behavior, and asset vulnerability status.               |
| High     | IAM / Web Admin               | Rotate Joomla administrator, database, hosting control panel, FTP/SFTP/SSH, and reused credentials after suspected or confirmed exposure.                | Stolen credentials cannot be used for post-patch persistence.                                                |
| High     | Hosting / Infrastructure      | Run a full server-side malware scan and review all sites in the same hosting account for cross-                                                          | Shared-hosting or multi-site compromise is scoped beyond                                                     |

|             |                               |                                                                                                                                                                                        |                                                                                                 |
|-------------|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
|             |                               | contamination.                                                                                                                                                                         | the initial Joomla site.                                                                        |
| Medium-High | Network / WAF                 | Restrict administrative and component-management paths where feasible, add WAF monitoring for JCE import attempts, and block direct access to uploadable PHP execution where possible. | Exploitability and post-exploitation utility are reduced even before full rebuild or migration. |
| Medium      | Business Owner / Web Platform | Decommission or migrate unsupported Joomla/PHP sites that cannot run current JCE safely.                                                                                               | Stopgap patches do not become permanent compensating controls for unsupported stacks.           |

Recommended remediation sequence:

1. Identify all Joomla/JCE deployments and determine whether each site is public, partner-facing, internal, or dormant.
2. Immediately export and preserve relevant web-server, WAF/CDN, hosting, and Joomla logs before rotation.
3. Upgrade to JCE 2.9.99.6 or later; if blocked by PHP/Joomla support constraints, apply the vendor patch package and document the exception.
4. Search for `index.php?option=com\_jce&task=profiles.import` and similar JCE profile-import activity; determine earliest suspicious access.
5. Review JCE editor profiles for unfamiliar names, unusual ordering, or upload policies that permit executable script extensions.
6. Search `images`, `media`, `tmp`, and configured JCE upload directories for PHP, PHTML, PHAR, or files with `php` in the name.
7. Hash and preserve suspicious artifacts, then remove attacker profiles and payloads or rebuild from known-good backup predating first suspicious access.
8. Rotate Joomla admin, hosting, database, FTP/SFTP/SSH, and reused credentials; invalidate active sessions where the platform supports it.
9. Run server-side malware scanning and review other sites in the same hosting account for related payloads.
10. Add recurring monitoring for JCE version drift, public exposure, and upload-folder executable content.

## 8. References

- [1] CISA Known Exploited Vulnerabilities Catalog, CVE-2026-48907 entry, added 2026-06-16. [https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field\\_cve=CVE-2026-48907](https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-48907)
- [2] CISA KEV JSON feed, catalog version 2026.06.16. [https://www.cisa.gov/sites/default/files/feeds/known\\_exploited\\_vulnerabilities.json](https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json)
- [3] CVE Program record, CVE-2026-48907. <https://cveawg.mitre.org/api/cve/CVE-2026-48907>
- [4] JCE vendor advisory, "JCE security update, and a free patch for older sites," created 2026-06-12. <https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites>
- [5] JCE editor changelog. <https://www.joomlacontenteditor.net/support/changelog/editor>
- [6] BleepingComputer, Sergiu Gatlan, "CISA orders feds to patch max severity Joomla plugin flaw by Friday," 2026-06-17. <https://www.bleepingcomputer.com/news/security/cisa-orders-feds-to-patch-max-severity-joomla-plugin-flaw-by-friday/>
- [7] YesWeHack, "CVE-2026-48907: Unauthenticated RCE in the Joomla Content Editor extension," 2026-06-12. <https://www.yeswehack.com/news/rce-joomla-content-editor-extension>
- [8] CISA Binding Operational Directive 26-04, Prioritizing Security Updates Based on Risk. <https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk>